WAC 4.0 : les serveurs Windows, l'annuaire et les sites web

Centre d'Excellence Cyberdéfense Aérospatiale (CEC), École de l'air et de l'espace

Les articles consacrés aux versions 2.0 et 3.0 présentaient WAC (Windows Artefacts Collector) : un collecteur libre, en C++, qui lit les volumes en brut, sans rien écrire sur la machine examinée, et couvre les postes de XP SP1 à Windows 11. La version 4.0 passe aux serveurs : toutes les générations de Server 2003 à 2025, les annuaires des contrôleurs de domaine, les stratégies de groupe, les serveurs web et les rôles DNS, DHCP et Hyper-V.

Tous les serveurs, de 2003 à 2025

Les mêmes exécutables collectent Server 2003, 2008 R2, 2012, 2012 R2, 2016, 2019, 2022 et 2025, ainsi que Server 2022 en installation Core. Chacun a passé le cycle de test sur le serveur lui-même, et ce passage a trouvé ce qu'un poste ne montrait pas : un bloc LZX final de taille impaire qui faisait lire `shell32.dll` à moitié, des formats anciens de Defender, le ShimCache de Server 2003, désormais décodé. Server 2008 hors R2 n'est pas mesuré, faute d'image officielle. Les cycles tournent comme sur le terrain : WAC est lancé depuis une clé USB et y écrit, jamais sur le disque examiné.

L'annuaire, sans ses secrets

Sur un contrôleur de domaine, `ntds.dit` et ses journaux sont copiés par lecture brute, sans LDAP ni réplication ; les journaux sont rejoués dans la copie de travail, car les objets récents ne sont que là. WAC en tire chaque objet, supprimés compris, chaque valeur d'attribut lié avec sa date de retrait (qui est entré dans un groupe, et qui en est sorti), les métadonnées de réplication attribut par attribut, et les descripteurs de sécurité, où se lisent les droits d'une attaque DCSync. **Les secrets ne sont ni lus ni émis** : seule une liste fermée d'attributs est décodée, et un attribut inconnu du schéma reste non lu. La copie de `ntds.dit` les contient chiffrés, et se protège comme une ruche.

Les stratégies de groupe

`SYSVOL` est lu de même. Pour chaque stratégie : valeurs de registre de `Registry.pol`, scripts, tâches planifiées des préférences, modèle de sécurité. Un mot de passe enregistré dans une préférence (`cpassword`) est signalé par son fichier ; sa valeur n'est pas écrite.

Les serveurs web

IIS, Apache et nginx sont trouvés par leur configuration et leurs services : sites, pools, modules, journaux d'accès et d'erreurs, en UTC. Le dossier de chaque site est copié en entier, avec les webshells qu'il peut contenir. Les chaînes de connexion de `web.config` désignent les bases à prendre ; les comptes des bases SQLite en sont extraits avec le schéma de leur condensat (phpass, bcrypt, ASP.NET Identity), et les dossiers de données de MySQL, MariaDB et PostgreSQL sont prélevés. Non lus : `wp-config.php` et `.env`.

Les rôles et les accès

DNS (réglages et DLL de greffon, zones, journal de débogage), DHCP (étendues et baux de `dhcp.mdb`, journaux d'audit) et Hyper-V (machines et chemins de leurs disques) sont confrontés à ce que chaque rôle dit de lui-même. Le journal des accès utilisateurs (`LogFiles\Sum`), qu'une comparaison à KAPE a montré manquant, dit par rôle, compte et adresse qui a joint le serveur, et quels jours ; ses bases sont confrontées à `dissect.esedb`.

Vérifié contre l'annuaire vivant

Sur un contrôleur Server 2022, les 3 711 objets rendus par WAC sont identiques à ceux de `Get-ADObject`. Le lecteur ESE de WAC, confronté à `dissect.esedb` sur le même `ntds.dit`, donne 145 421 valeurs sans aucune différence. Les stratégies sont confrontées à une stratégie témoin, les événements du contrôleur à `Get-WinEvent`. Une demande de réplication par DirSync laisse un événement 4662 du droit `1131f6aa`, retrouvé dans la collecte.

Ce qui reste à mesurer

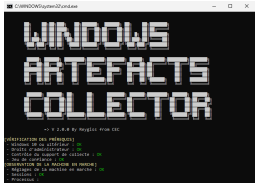
L'annuaire est mesuré sous Server 2008 R2, 2012 R2, 2016, 2022 et 2025, non sous 2003 (copié, non converti), 2012 ou 2019. Un second contrôleur, un `sIDHistory` réel et un attribut d'extension du schéma ne sont mesurés que sous Server 2022. La réplication témoin est celle d'un vrai contrôleur, avec le droit `1131f6ad` que demande aussi un DCSync : l'outil d'un attaquant n'est pas lancé. Les dates d'accès d'un contrôleur sont éteintes : le contrôle d'innocuité n'y prouve que le numéro USN. La comparaison à KAPE sous Sysmon reste celle du poste de la 3.0.

En chiffres

Artefacts prélevés (3.0 : 80)	87
Générations de serveurs mesurées	2003 à 2025
Contrôles du cycle, contrôleur	609
Contrôles du cycle, Windows 11	605
Objets identiques à `Get-ADObject`	3 711
Valeurs de `ntds.dit` égales à dissect	145 421
Secrets de l'annuaire lus ou émis	0

Disponibilité

Version 4.0.0, Windows XP SP1 à 11 et Server 2003 à 2025 (x86 et x64), licence GPL 3.0 : `https://github.com/dev-cec/WAC`. Manuels, dossiers de validation, d'innocuité et de comparaison en français et en anglais ; cycles serveurs du 31 octobre au 8 novembre 2026.



WAC en cours de collecte.